

Silvia Sisinni

silvia.sisinni@polito.it



Module A – Cybersecurity Fundamentals

A3 – Security Properties & Crypto



**Politecnico
di Torino**

Department of Control and
Computer Engineering



TORSEC

Computer and Network Security Group



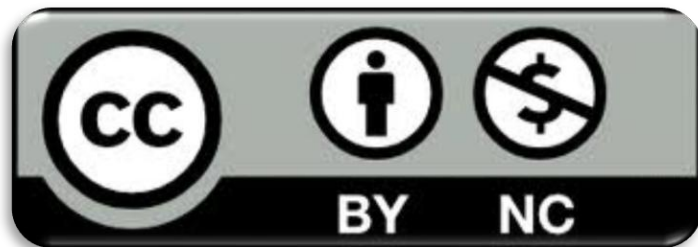
Acknowledgments

This lecture deck *adapts* and *reorganizes* selected teaching material originally developed by Nicolò Maunero (CINI / Cybersecurity National Lab). Portions of the content are reused under the Creative Commons BY-NC license (see license slide). All modifications, additions, re-organization, and any errors are the responsibility of the course instructor.

License & Disclaimer

License Information

This presentation is licensed under the
Creative Commons BY-NC License



To view a copy of the license, visit:

<http://creativecommons.org/licenses/by-nc/3.0/legalcode>

Disclaimer

- We disclaim any warranties or representations as to the accuracy or completeness of this material.
- Materials are provided “as is” without warranty of any kind, either express or implied, including without limitation, warranties of merchantability, fitness for a particular purpose, and non-infringement.
- Under no circumstances shall we be liable for any loss, damage, liability or expense incurred or suffered which is claimed to have resulted from use of this material.
- This material is used and adapted within the course “Cybersecurity and National Defense”.



Learning goals

By the end of this lecture, you should be able to:

1. Conceptual Foundations of Information Security

- Distinguish *data vs information* and explain inference-based risks.
- Define and interpret the *CIA triad*.
- Understand additional security properties: *authenticity, accountability, non-repudiation*.

2. Threat Mapping

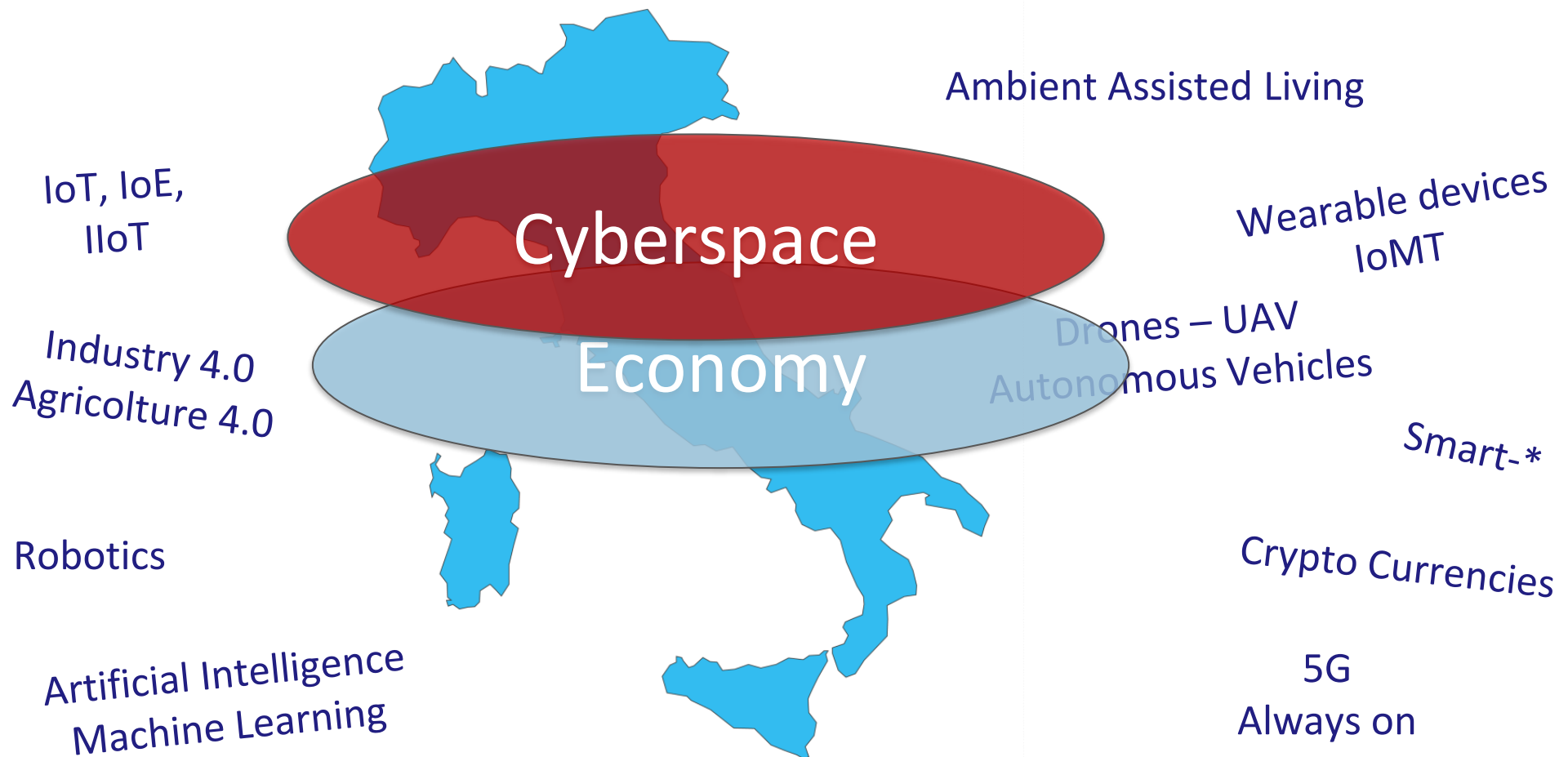
- Map attacker capabilities (read, modify, block, inject) to violated properties.
- Analyze simple communication threat models.

3. Technical Mechanisms

- Explain the principles of:
 - Symmetric cryptography
 - Public-key cryptography
 - Cryptographic hash functions
 - Message Authentication Codes (MACs) and Digital Signatures

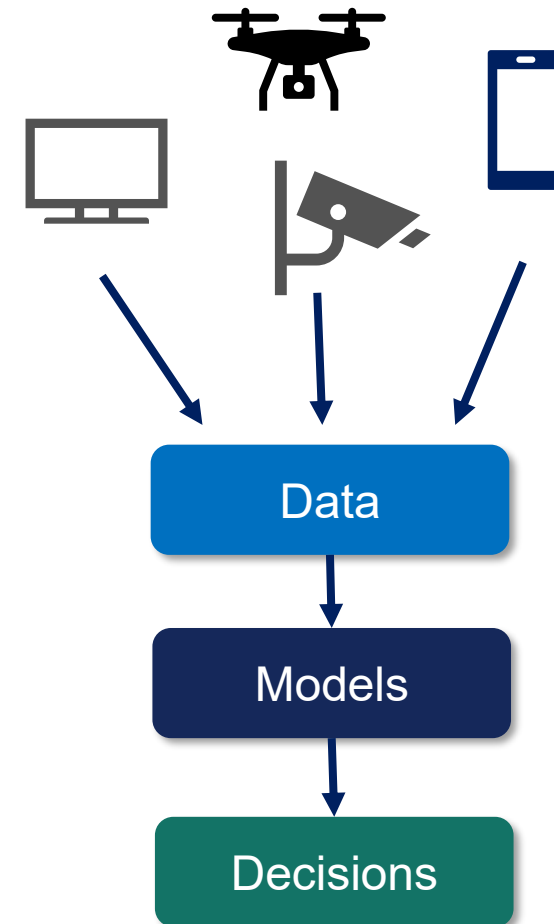


Cyberspace -- Pervasiveness



Consequences of pervasive cyberspace

- *Big Data*: massive, heterogeneous data streams collected continuously.
- *Datacracy*: decisions and power increasingly depend on data access and analytics.
- *Data-driven Society*: services, markets, and institutions optimize using data and models.
- *Security implication*: more data + more connectivity ⇒ **more exposure, more inference, more impact.**



Datacracy

There is a revolution underway, the digital revolution, by which we are all overwhelmed by the tsunami of information to which it gives rise.

The amount of data we produce is doubling every year: in 2018 we generated as much data as in the entire history of humanity until 2017. Every minute in the world hundreds of thousands of Google searches and Facebook 'posts' are made, containing information, which reveals what we do, feel and think: who we are. With the development of the Internet of Things, within less than ten years we will have 150 billion devices and sensors, 20 times more than there are humans on Earth, connected to each other and to people in an immense global network. Then the amount of data will double every 12 hours.

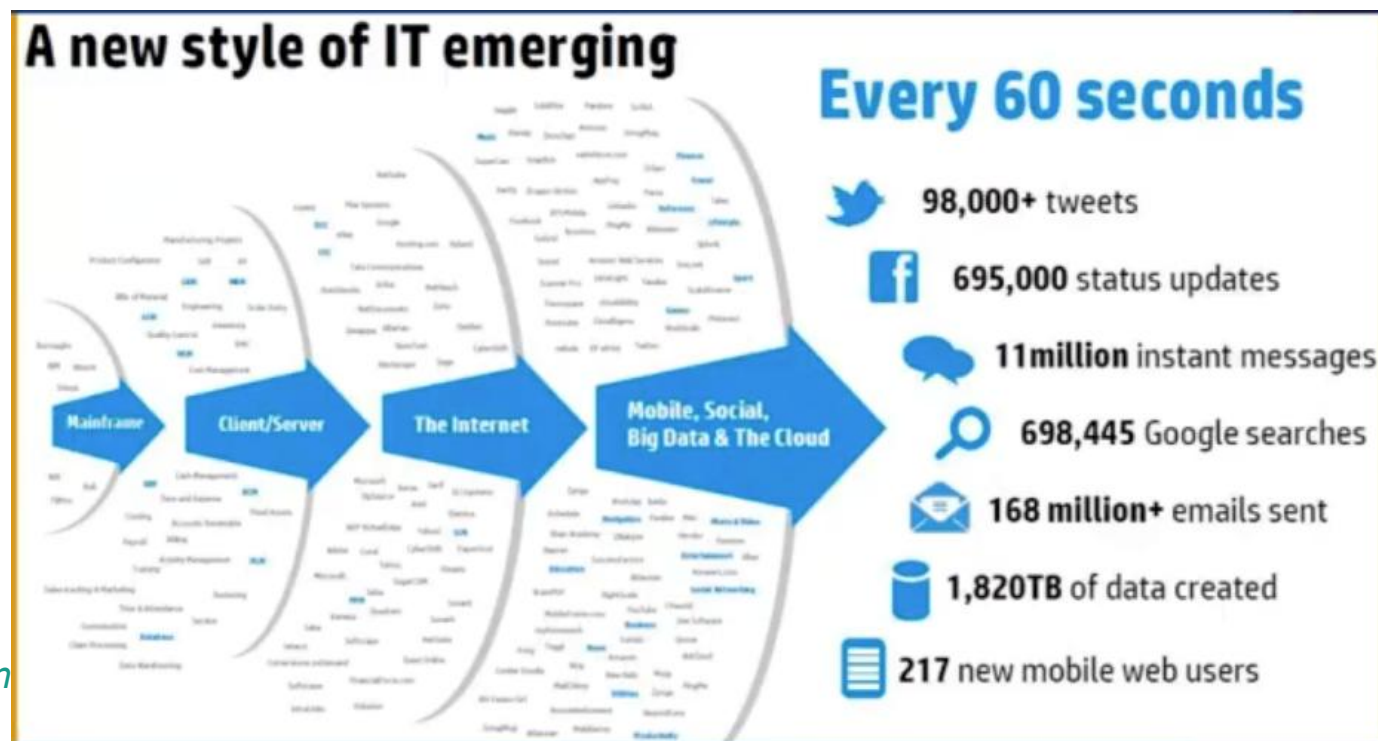
And everything will be able, at least in principle, to become 'smarter'; soon we will have not only smart phones but smart homes, smart factories, smart cities, smart cars; and the question is: will we humans know how to be smarter?



[Mario RASETTI – ISI Foundation,
Turin]

Scale makes privacy and security systemic

- Security is no longer about single systems → **it's about ecosystems.**
- At scale, small leaks become **mass surveillance** and **mass exploitation.**

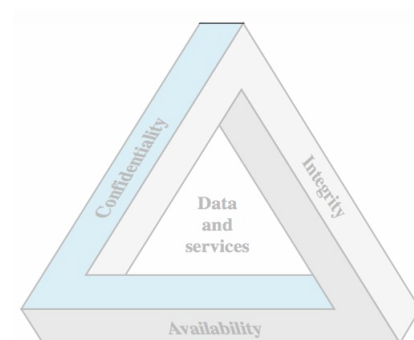


Roadmap

➤ Data vs Information & Inference

➤ CIA Triad

- Confidentiality
- Integrity
- Availability



➤ Threats to CIA (simple communication model)

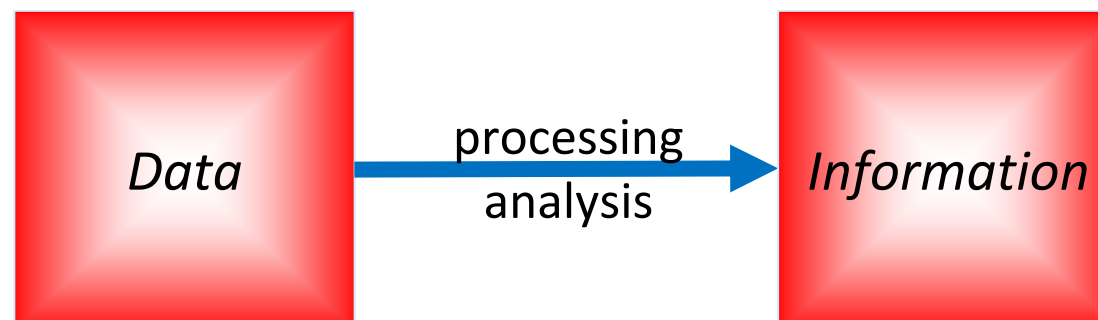
➤ Cryptographic countermeasures

- Encryption
- Hash functions
- MACs
- Digital signatures

➤ Access Control architectures

Data vs Information

- Data and information are distinct but deeply related elements.
- **Data** typically refer to raw or unprocessed items.
 - Example: “ZIP = 13053”, “Age = 31”, GPS coordinate, timestamp
- **Information** is the meaning inferred from data + context
 - Example: “Bob has cancer”, “Bob’s home address”, “Bob’s daily routine”





Information



- *Form of knowledge acquired, transmitted, or shared through data associated with a specific fact or circumstance.*



Information



- *A sequence of symbols that can be interpreted as a message useful in providing knowledge or details in relation to a particular topic.*



Data vs Information

- Information is more general than data.
- Data convey information
- But information may also be revealed, without revealing data, e.g., by statistical summaries.

Quick check: data leak or information leak?

A hospital publishes: 'Average age of patients in Ward X is 31'.

Question:

Could this reveal **information** about a specific patient? When?

Answer:

Yes. If Ward X has **very few** patients or auxiliary information is available.

Inference attack: learning sensitive information indirectly

- Alice and Bob are close but enemies.
- One day Bob is taken by ambulance to the hospital.
- Alice wants to learn Bob's medical condition.
- Alice obtains a dataset of medical records where Bob is included.

Quasi-identifiers (can re-identify when combined)

Sensitive attribute

	Non-Sensitive			Sensitive
	Zip Code	Age	Nationality	Condition
1	130**	< 30	*	Heart Disease
2	130**	< 30	*	Heart Disease
3	130**	< 30	*	Viral Infection
4	130**	< 30	*	Viral Infection
5	1485*	≥ 40	*	Cancer
6	1485*	≥ 40	*	Heart Disease
7	1485*	≥ 40	*	Viral Infection
8	1485*	≥ 40	*	Viral Infection
9	130**	3*	*	Cancer
10	130**	3*	*	Cancer
11	130**	3*	*	Cancer
12	130**	3*	*	Cancer



Inference attack: learning sensitive information indirectly

Threat model

- **Attacker:** Alice
- **Target:** Bob's medical condition
- **Data source:** leaked dataset
- **Auxiliary info:** neighborhood knowledge



Linkage + inference $\Rightarrow$ privacy breach

- Since Alice is Bob's neighbor, she knows that:
 - Bob's **Age** = **31**
 - his **Zip** code is **13053**
- Alice finds the matching rows (9 – 12).
- All matching rows share the same condition
- $\Rightarrow$ Alice infers **Bob has cancer**.

	Non-Sensitive			Sensitive
	Zip Code	Age	Nationality	Condition
1	130**	< 30	*	Heart Disease
2	130**	< 30	*	Heart Disease
3	130**	< 30	*	Viral Infection
4	130**	< 30	*	Viral Infection
5	1485*	≥ 40	*	Cancer
6	1485*	≥ 40	*	Heart Disease
7	1485*	≥ 40	*	Viral Infection
8	1485*	≥ 40	*	Viral Infection
9	130**	3*	*	Cancer
10	130**	3*	*	Cancer
11	130**	3*	*	Cancer
12	130**	3*	*	Cancer



Machine Learning and Inference Attacks

- Machine Learning (ML) models can **infer sensitive attributes from seemingly harmless data**
- Example attacks: membership inference, attribute inference, model inversion
- Attackers exploit **statistical patterns in data**
- Applications:
 - Inferring User Actions from Encrypted Network Traffic (“**Analyzing Android Encrypted Network Traffic to Identify User Actions**”, Mauro Conti et al., IEEE TIFS.)
 - Inferring What You Type from Keyboard Sound (“**Don't Skype & Type! Acoustic Eavesdropping in Voice-Over-IP**”, Compagno, Conti, Lain, Tsudik)
 - Inferring PIN Codes from Sound Timing (“Your PIN Sounds Good! On the Feasibility of PIN Inference Through Audio Leakage”, Cardaioli, Conti, et al.)

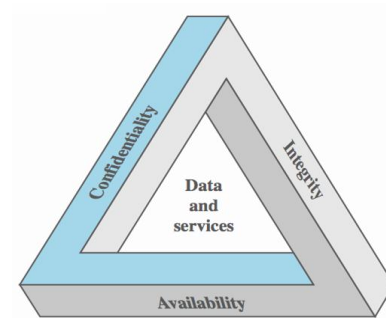


Roadmap

➤ Data vs Information & Inference

➤ CIA Triad

- Confidentiality
- Integrity
- Availability



➤ Threats to CIA (simple communication model)

➤ Cryptographic countermeasures

- Encryption
- Hash functions
- MACs
- Digital signatures

➤ Access Control architectures



Information Security

- Preserving information *Confidentiality, Integrity, Availability (CIA)*.
 - *Confidentiality*: prevent unauthorized disclosure.
 - *Integrity*: prevent unauthorized modification.
 - *Availability*: ensure timely, reliable access.
- CIA applies to **data and services** (e.g., communication, control, decision support).

[standard ISO/IEC 27000:2014 e ISO/IEC 27032:2012]



Confidentiality



- *Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information...*
- *Information is not learned by unauthorized entities.*
- If confidentiality fails, we usually talk about a **data breach**.
- Confidentiality is typically enforced using mechanisms such as:
 - encryption
 - access control
 - authentication

[US Federal Information Security Management Act (FISMA) -
United States Code, 2006 Edition, Supplement 5, Title 44]



Integrity



- *Property that guarantees that information is not modified or destroyed without authorization.*
 - Example of attacks:
 - In a financial system, an attacker cannot be able to change the amount of a bank transfer
 - In industrial control systems, an attacker cannot be able to modify commands sent to industrial machines
 - Related but distinct properties:
 - *Authenticity*: the message/source is genuine.
 - *Non-repudiation*: a party cannot plausibly deny an action.
- [US Federal Information Security Management Act (FISMA) -
United States Code, 2006 Edition, Supplement 5, Title 44]



Integrity has two scopes

- *Data integrity*: Assures that data and programs are changed only in a specified and authorized manner.
 - Example: transaction amount, medical dosage record
- *Systems Integrity*: Assures that a system performs its operations in unimpaired manner, free from unauthorized manipulations.
 - Example: OS kernel, firmware logic, applications, configurations.
 - **Trusted Computing** is the research field that studies techniques to detect if a system has been compromised.



Authenticity



- *The property of being "genuine" and being able to be verified and credible.*
- *Confidence in the validity of a transmission, message, or the author of the message.*
- Question answered: "Did this message really come from **who it claims** to come from?"
- Typical mechanisms: digital signatures, Message Authentication Codes (MACs), authenticated protocols.

[NIST SP 800-137 under Authenticity (CNSSI 4009)

NIST SP 800-30 Rev. 1 under Authenticity (CNSSI 4009)

NIST SP 800-39 under Authenticity

NIST SP 800-53 Rev. 4 under Authenticity

NIST SP 800-53A Rev. 4 under Authenticity]



Accountability



- *The property that enables actions of an entity (user, process, device) to be **uniquely traced** to that entity.*

Purpose

- Supports incident response and forensics
- Enables auditing and compliance
- Acts as a deterrent against misuse

Typical mechanisms

- Secure logging
- Tamper-evident audit trails
- Identity binding (authentication + access control)

[CNSSI 4009-2015; NIST SP 800-53 (Accountability controls)]



Non-repudiation



- *The property that provides protection against an entity **falsely denying** having performed a particular action.*

What it guarantees

- Non-repudiation provides **cryptographic evidence** that the action actually occurred.
- For example: a sender cannot deny having sent a message; a person cannot deny having digitally signed a document.

Typical mechanisms

- Digital signatures, trusted timestamping, secure key management, strong identity binding

Important distinction

- Accountability enables tracing.
- Non-repudiation provides **cryptographic evidence**.

[CNSSI 4009;

NIST SP 800-53 (Non-repudiation services)]



Authentication (AuthN)

- Authentication verifies **who** is requesting access (person or system).
- Common factors:
 - **something you know** (password, PIN) 
 - **something you have** (token, smart card) 
 - **something you are** (biometrics) 
- Stronger practice: combine multiple factors, **Multi-Factor Authentication (MFA)**.

NOTE: Authorization (AuthZ) decides **what** you can do (next slides).



Availability



- *Ensuring timely and reliable access to and use of information.*
 - *Data/services can be accessed when desired.*
 - Threats:
 - Denial of Service (**DoS**) / Distributed Denial of Service (**DDoS**): attackers overload servers with a lot of requests in order to prevent the provision of the service to users who request it
 - ransomware outages: systems are locked
 - physical disruption, e.g., power failures
- [US Federal Information Security Management Act (FISMA) -
United States Code, 2006 Edition, Supplement 5, Title 44]



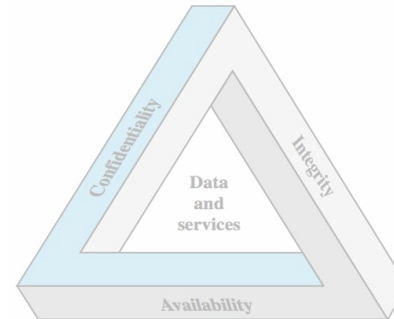
Availability as a reliability concept



- *The probability $A(t)$ that the system will function correctly at a given instant t .*
- In practice we use operational metrics like
 - **Uptime**: the percentage of time a service is operational and accessible
 - **Mean Time Between Failures (MTBF)**, the average time a system operates correctly between one failure and the next.
 - **Mean Time to Repair (MTTR)**, the average time required to detect, fix, and restore a system after a failure.
- Many services publish availability guarantees in their **service level agreements**.
 - For example, cloud providers often advertise “**five nines**” availability, which corresponds to **99.999% uptime**
 - That translates to roughly **five minutes of downtime per year**.

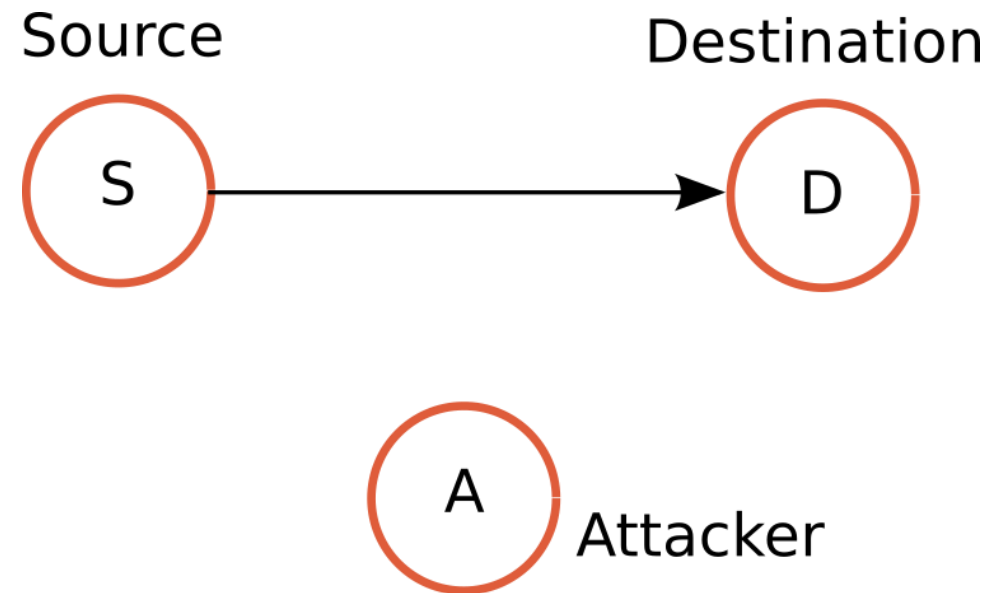
Roadmap

- Data vs Information & Inference
- CIA Triad
 - Confidentiality
 - Integrity
 - Availability
- Threats to CIA (simple communication model)
- Cryptographic countermeasures
 - Encryption
 - Hash functions
 - MACs
 - Digital signatures
- Access Control architectures



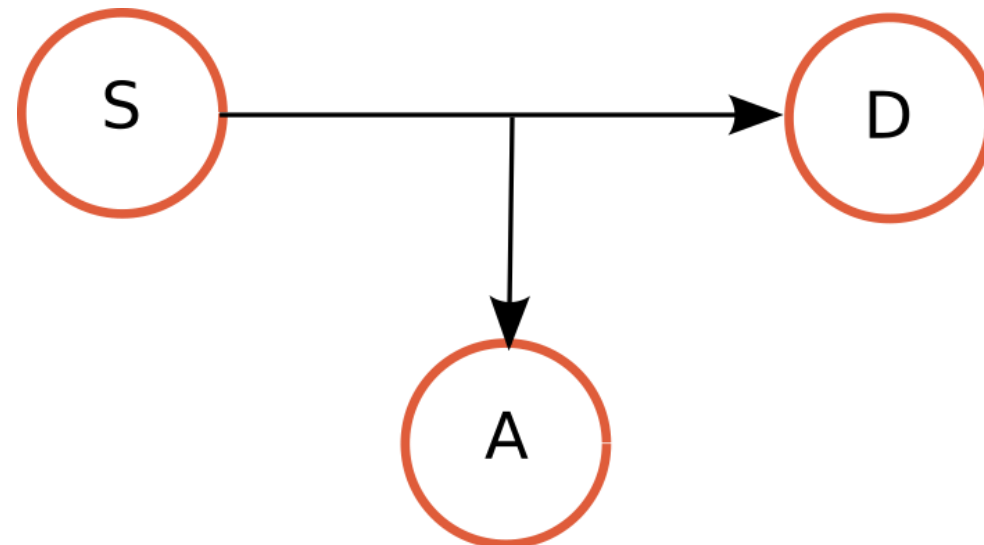
Threat model: source–destination with an attacker

- A message/service flows from **Source (S)** to **Destination (D)**.
- Attacker **A** may:
 - **Read** (eavesdrop)
 - **Modify** (tamper)
 - **Block** (deny)
 - **Inject** (forge)



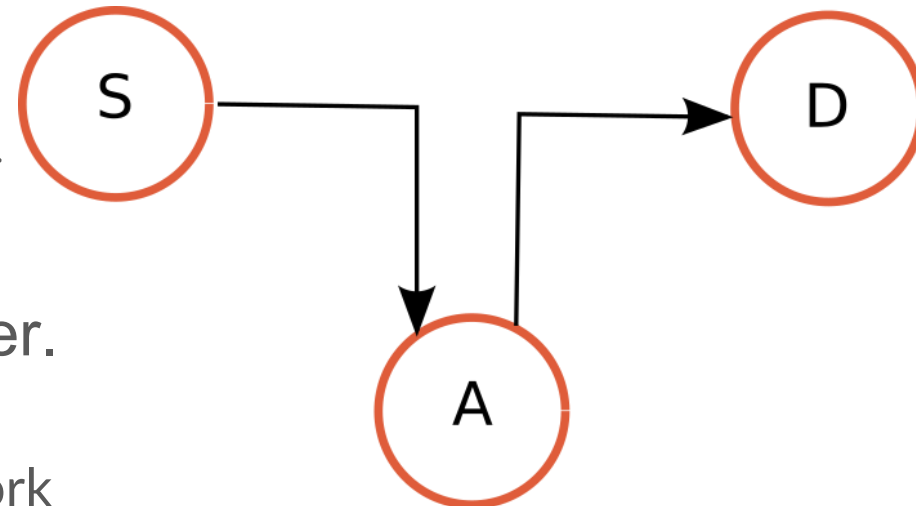
Stealing → attack to confidentiality

- Attacker gains *unauthorized access* to information → so, he breaks *confidentiality*.
- **Examples:** network package sniffing of data sent “in clear” (unencrypted); accessing a vulnerable database.
- **Typical controls:** encryption (in transit/at rest), access control, network segmentation.



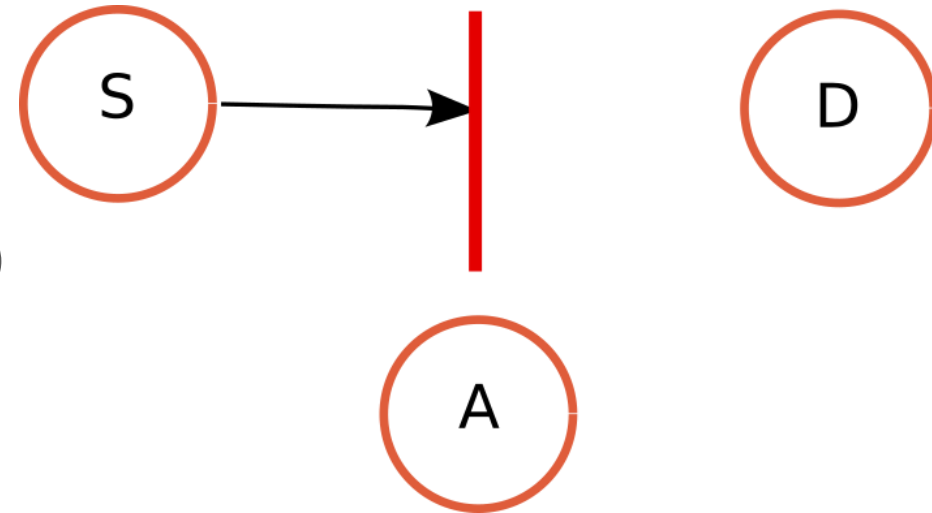
Corrupting → attack to integrity

- Attacker *modifies* information in transit (i.e., over the network) or at rest (in the storage of a system) → so, he breaks *integrity*.
- Example: redirecting a bank transfer.
 - NOTE: The attacker A can be either in the browser (malware) or on the network (*Man-in-the-Middle (MitM)*).
- Typical controls: Message Authentication Codes (MACs), digital signatures, secure communication protocols such as TLS



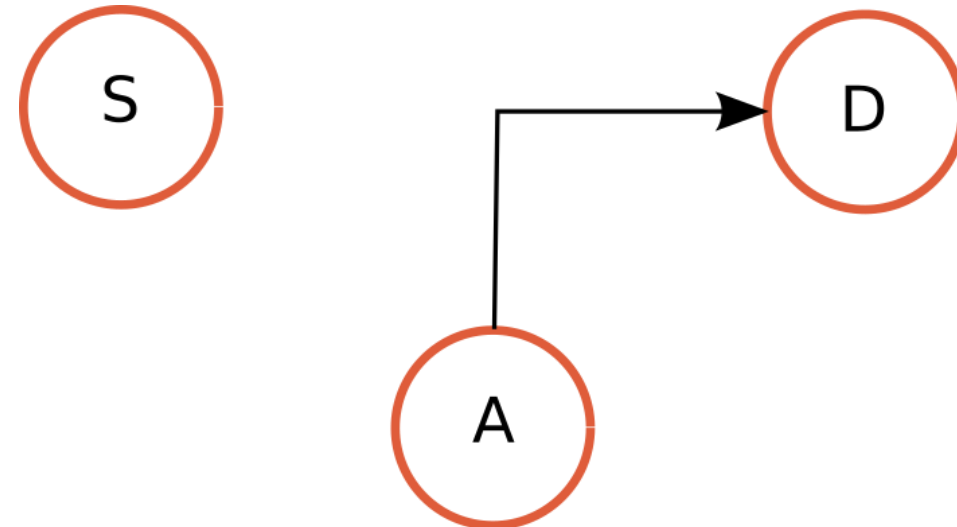
Inhibiting → attack to availability

- Attacker *stops* or *degrades* the information/service flow → so, he breaks *availability*.
- Examples: Denial of Service (DoS) / Distributed Denial of Service (DDoS); disruption of critical infrastructure operations.
- Typical controls: **redundancy** (replicate critical components), **rate limiting** (limit the number of requests a source can do), **distributed infrastructures** (service deployed across geographically distributed data centers), **incident response** (monitoring, detection and response mechanisms).



Forging → attack to authenticity

- Attacker *injects* a fake message/object that appears legitimate → so, he breaks *authenticity*.
- Example: phishing, software supply chain attacks
 - weak cryptographic design
 - stolen cryptographic keys
 - implementation vulnerabilities
- Typical controls: digital signatures, secure key management, verification.

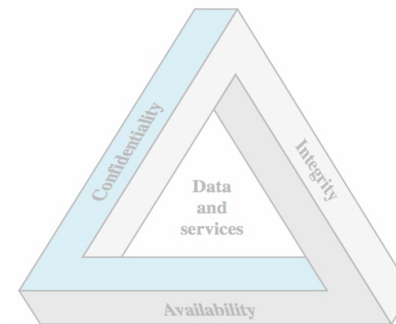


Roadmap

➤ Data vs Information & Inference

➤ CIA Triad

- Confidentiality
- Integrity
- Availability



➤ Threats to CIA (simple communication model)

➤ Cryptographic countermeasures

- Encryption
- Cryptographic hash functions
- MACs
- Digital signatures

➤ Access Control architectures



Countermeasures are layered

- Attacks can target any level: hardware, software, networks, and people.
- Effective defense uses **layered controls** (defense-in-depth).
- We will focus on just three examples of possible countermeasures for message protection:
 - *Encryption* (confidentiality)
 - *Message Authentication Code* (Integrity/authenticity)
 - *Digital Signatures* (Integrity/authenticity/Non-repudiation)

Encryption



- Operation that, resorting to an **encryption algorithm** and a **key**, renders a message “blurred”, so that it is not comprehensible/intelligible to persons not authorised to read it.
- The message is transformed using an **encryption algorithm** and a **cryptographic key**
 - the result is **ciphertext**
- Provides **confidentiality** against unauthorized readers.
- Security of a cryptographic system depends on **key management**, not on secrecy of the algorithm (**Kerckhoffs’s principle**)
 - This design philosophy is essential for building **robust and publicly verifiable cryptographic systems**.

Encryption & Decryption

- Use encryption to protect data **in transit** (network) and **at rest** (storage).





Principles of *Symmetric Cryptography*

- One **shared secret key K** is used for both operations

$$\textbf{Encrypt: } C = E(K, M) \qquad \textbf{Decrypt: } M = D(K, C)$$

- Security depends on keeping **K secret** and distributing it safely (**key exchange** problem).
- Very efficient → used for **bulk data** (files, disks, network traffic).
- Main challenge: **how do two parties get K securely** at scale?
- In real systems: asymmetric cryptography is used to securely exchange a session key, which is used to encrypt session data through symmetric encryption.



Principles of *Asymmetric Cryptography*

- Each entity has 2 keys:
 - *Public key* (publicly disclosed by the entity)
 - *Private key* (kept secret by the entity)
- The two keys can be used (in a complementary way) for encryption/decryption.
- **Public-key encryption** $\Rightarrow$ *confidentiality*
 - encrypt with recipient's public key
 - decrypt with recipient's private key
- **Digital signatures** $\Rightarrow$ *integrity + authenticity + non-repudiation*
 - sign with sender's private key
 - verify with sender's public key



Cryptographic Hash Functions



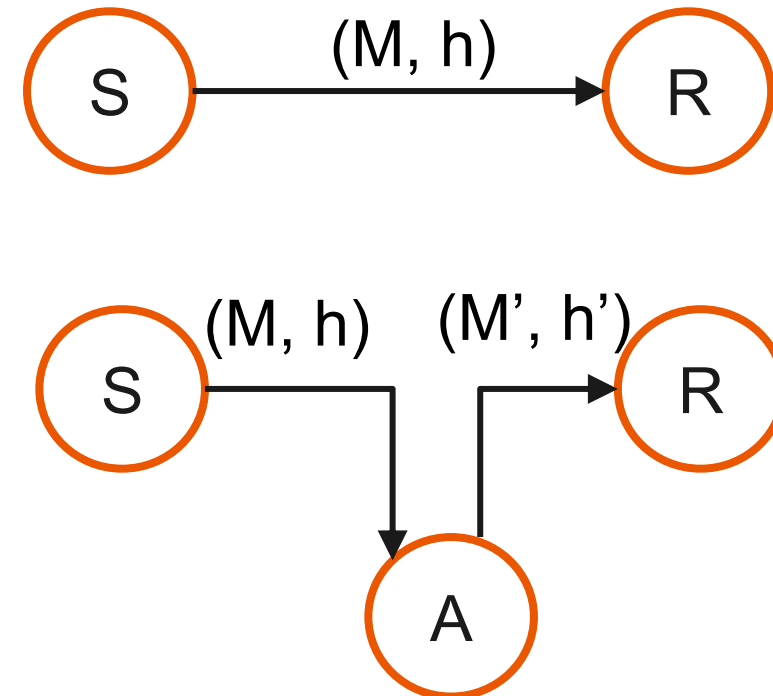
- *A Hash function:*
 - gets in input a message M (any length)
 - returns in output a hash value h (fixed length), often referred to as *digest*

$$h = H(M)$$

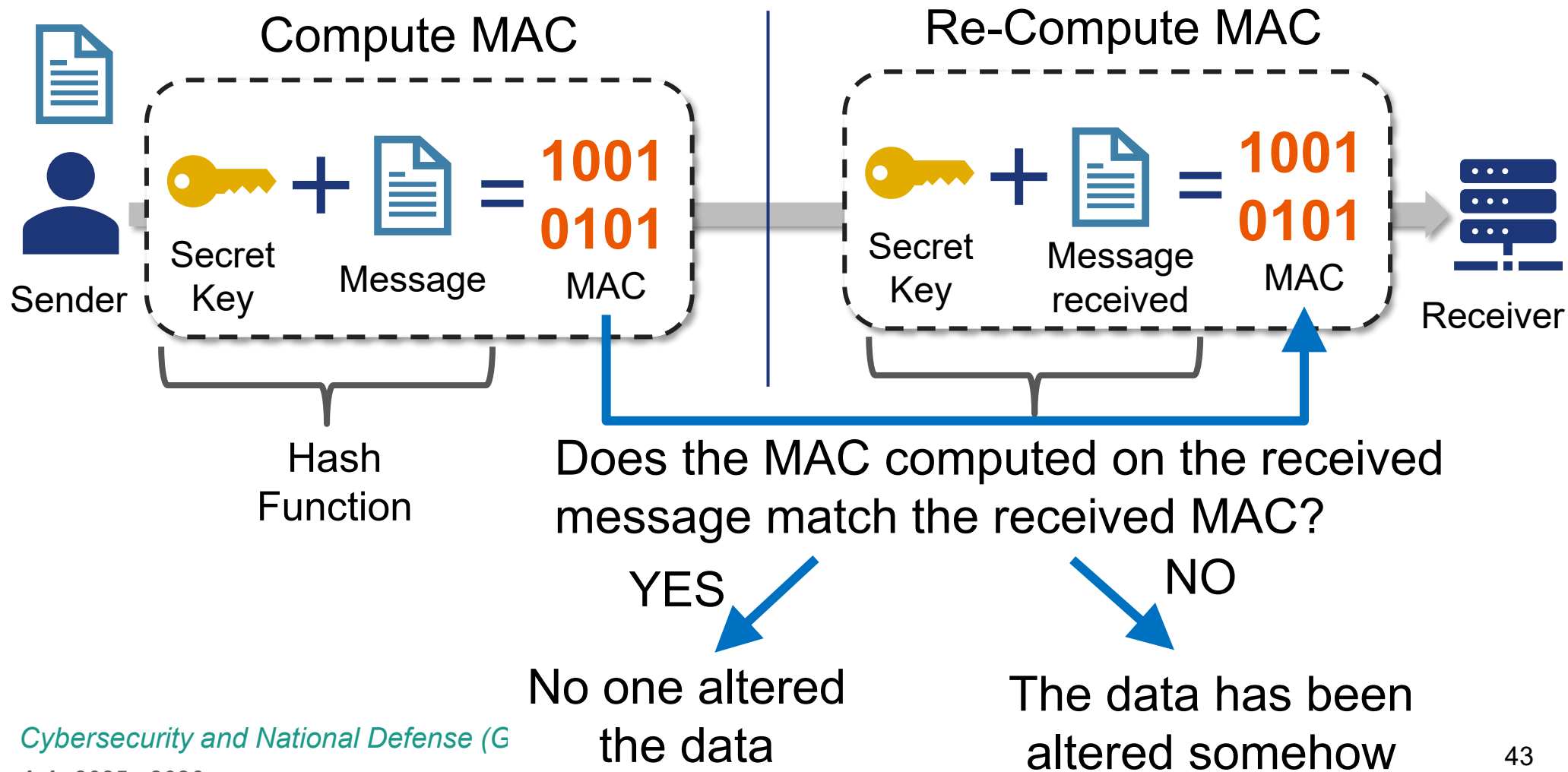
- Desired properties:
 - hard to reverse (**one-way**)
 - hard to find two messages with same digest (**collision resistance**)

Hashes can detect accidental changes

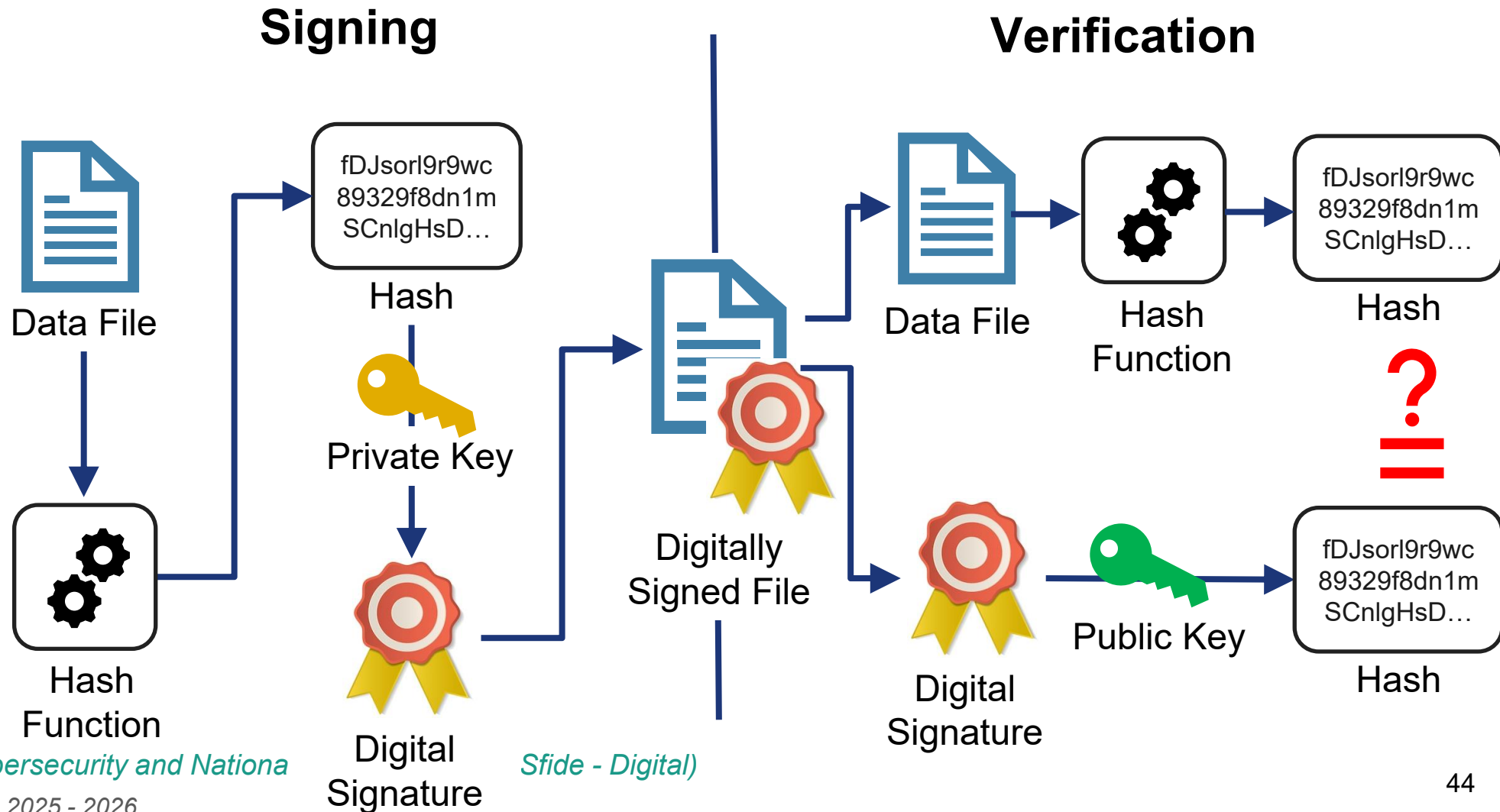
- If sender sends **M** and **$h = H(M)$** , receiver can check if M changed.
- This detects **errors** (corruption, e.g., transmission errors, storage failures), when the attacker *cannot alter both*.
- For active attackers, hash alone is not enough → we need **authenticated integrity**
 - **MAC** (Message Authentication Code) (shared secret key)
 - **Digital signature** (public verification) (public verification)



How Message Authentication Codes work

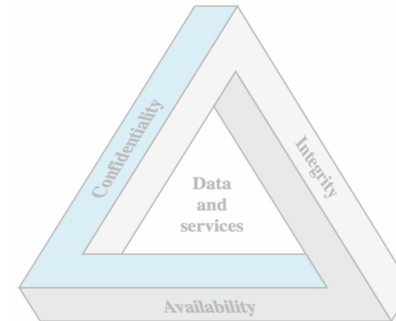


How Public-key Digital Signature work



Roadmap

- Data vs Information & Inference
- CIA Triad
 - Confidentiality
 - Integrity
 - Availability
- Threats to CIA (simple communication model)
- Cryptographic countermeasures
 - Encryption
 - Hash functions
 - MACs
 - Digital signatures
- Access Control architectures

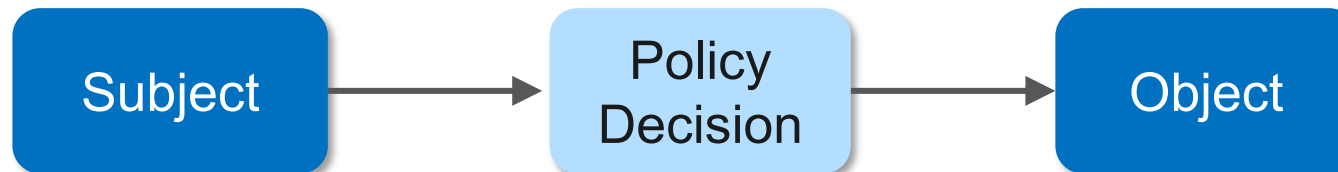


Access Control as Enforcement Mechanism

Security properties (confidentiality, integrity, availability) must be enforced by technical and organizational mechanisms.

Access Control is the primary mechanism that regulates:

- who can access which resources
- under which conditions
- for which operations



It operationalizes confidentiality, integrity and accountability.



Access Control



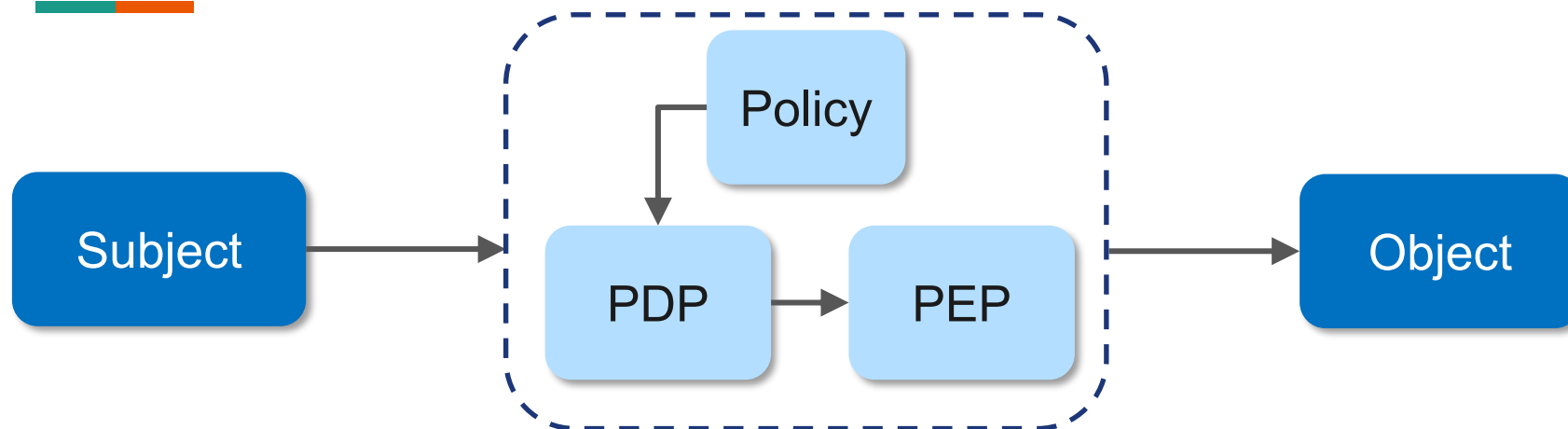
- *The process of granting or denying specific requests to obtain and use information and related information processing services, or to enter specific physical facilities.*

Interpretation:

- Applies to logical and physical domains
- Operates through policy enforcement
- Decisions are made based on predefined policies and contextual information

[CNSSI 4009-2015, adapted]

Logical Access Control



- **Subject** (user, process, device requiring access to a resource)
- **Policy Decision Point (PDP)**: evaluates the policies which apply to the subject and the object and decides whether access should be granted for that specific operation
- **Policy Enforcement Point (PEP)**: component capable to enforce the decision
- **Object** (resource requested by the subject)



Access Control Models

Model	Full Name	Decision Basis
DAC	Discretionary Access Control	Identity of subject and ownership of object
MAC	Mandatory Access Control	Security labels and classification levels
RBAC	Role-Based Access Control	Assigned organizational roles
ABAC	Attribute-Based Access Control	Attributes of subject, object, action, environment